



By Nitesh Singh

Job Ready Free Live Training To Become A

SOC

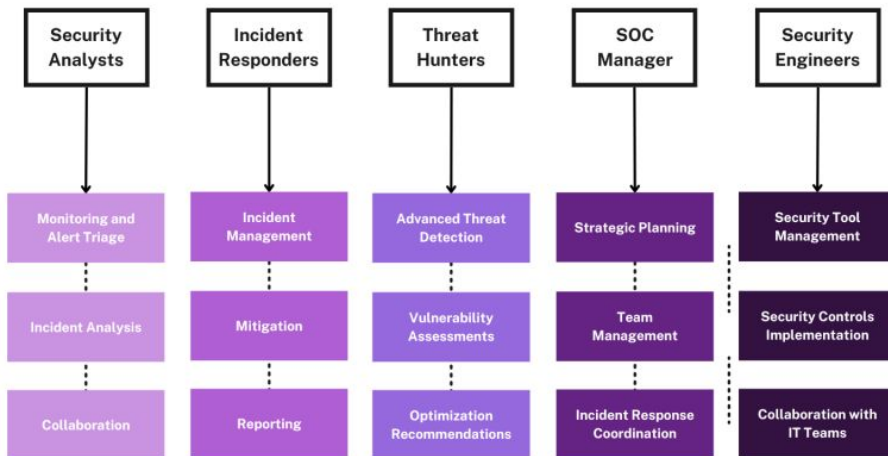
Analyst L1 For Free



The 3 SOC Operating Models

1. In-House (Internal) SOC

SOC Team Structure



A company builds and runs its own SOC internally using its own people, tools, and processes.

MSP vs MSSP

The Key Differences

IT Operations

Service provider focused on **managing IT operations**

Network / System Health Monitoring

Ensures that **IT systems** are running smoothly

Management

Network systems are **managed, updated, and maintained**

MSP Role

Manages a **DEFINED** set of agreed services

Network

Proactively **manages and maintains** infrastructure and solutions

Support

Provides **service and help for operations**

Aims

Meet **business operation** objectives

IT Security

Service provider focused on **managing IT security**

Security Monitoring / Defense

Ensures that **IT security** systems are overseen and protected at all times

Management

Security systems are **monitored constantly** to be as secure as possible

MSSP Role

Guards against constantly **EVOLVING** threats

Network

Proactively **monitors and defends** against cyberattacks

Support

Takes **proactive action when a threat is encountered**, using best practices for business continuity and disaster recovery

Aims

Meet **modern and future compliance and security** goals

02

Core Concept



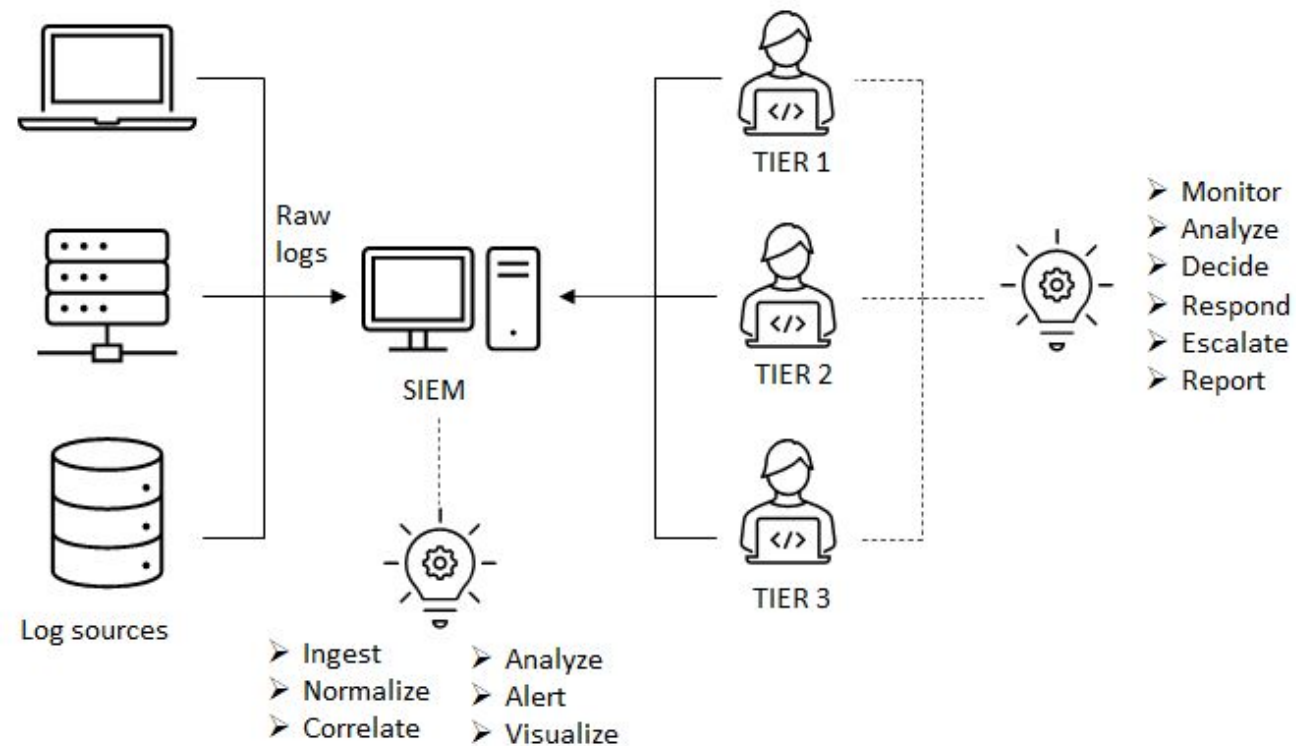
The 3 SOC Operating Models

2. Outsourced / Managed SOC (MSP/MSSP SOC)

A third-party security company (MSSP) provides SOC services to multiple client organizations.

MSP : Managed Service Providers

MSSP : Managed Security Service Providers



The 3 SOC Operating Models

3. Hybrid SOC (Co-Managed SOC)

A shared responsibility model between:

- Internal SOC team AND
- External MSSP



System As Attack Vectors

If you understand systems as attack vectors, you stop being a beginner and start thinking like an analyst. In SOC, we don't just protect users or data, we protect SYSTEMS, because every system can be abused as an attack vector.

A system becomes an attack vector when an attacker uses it to:

1. Gain initial access
2. Move laterally
3. Maintain persistence
4. Exfiltrate data
5. Launch further attacks



Human Oriented Attacks

Users are those who start the attack mostly : (Before external factors, Users are responsible at first)

By inserting a malicious USB found on a street, downloading malware from pirated resources, or simply reusing a weak password everywhere. 81% of breaches involve stolen or breached passwords.

Example :

- Rubber Ducky.
- Keyloggers binded with legitimate softwares.
- Clicking on suspicious links.
- Opening any email or sent attachments.
- Storing passwords at unsecure portals.
- Trusting soon.
- Using outdated/pirated softwares etc.



Supply Chain Attacks

Your PC is home to hundreds of apps, including web browsers, messengers, development, and entertainment software. Every app depends on thousands of libraries.

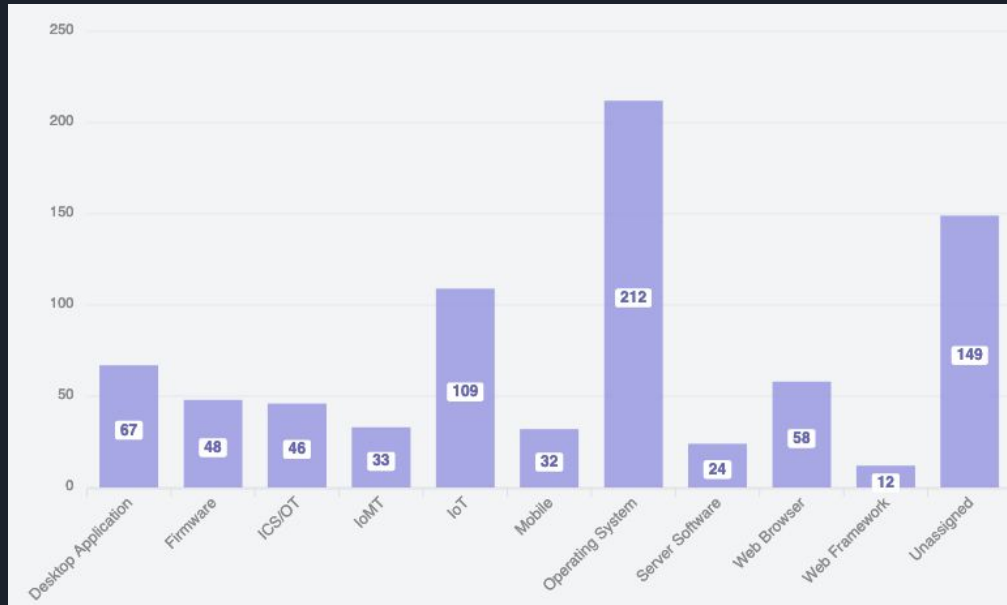
If threat actors manage to breach one of the apps or libraries and push an update to all its users, all of them will be compromised. This technique is called a **supply chain attack**. The most famous examples are the SolarWinds and 3CX breaches which affected thousands of companies.

It is hard to protect from supply chain attacks since you can't always control all the software present on your laptops, servers, and web apps.



Vulnerabilities

Every piece of software have security flaws. In 2024, over 40,000 software vulnerabilities were published and more than 300 were actively exploited in major attacks.



The vulnerabilities added by CISA to its catalog in 2022 impacted a wide range of products, but operating systems and IoT accounted for the highest percentages.



Vulnerabilities

A vulnerability is a weakness in a system, software, hardware, or process that can be exploited by an attacker to Gain access, Escalate privileges, Execute code. Steal data, Disrupt services & more...

“A vulnerability is a flaw or weakness in a system that can be exploited to compromise confidentiality, integrity, or availability.”

Vulnerabilities can exist in Softwares, OS, Applications, Network Devices, Firmwares, Cloud Services or even Security Software solutions



Software Vulnerabilities

Every piece of software has flaws, but some take years to be discovered. For example, Shellshock, a major Linux vulnerability, existed since 1992 but wasn't found until 2014. In the worst-case scenario, attackers discover the vulnerability before anyone else. This is known as a zero-day, and only your SOC skills can determine whether it gets detected in time.

Once a vulnerability is made public, it is assigned a Common Vulnerabilities and Exposures (CVE) number. From that moment, it's a race: attackers develop exploits while defenders rush to update their systems.

An answer to a CVE is always a patch - an update supplied by the software vendor. Even for zero-days, you'll have to wait for a patch, vigilantly monitor for exploitation traces, and try to survive the stressful period before the patch is released. For example, by:

- Restricting access to the system to only trusted IPs
- Applying temporary measures provided by the vendor
- Blocking known attack patterns on IPS or WAF



Software Vulnerabilities

Example of Software Vulnerabilities :

- SQL Injection
- Command Injection
- Buffer Overflow
- Cross-Site Scripting (XSS)
- Remote Code Execution (RCE)

SOC Detection :

- WAF alerts
- Web server logs
- Unusual POST requests
- EDR alerts on servers



Operating System Vulnerabilities

Example of Operating System Vulnerabilities :

- Windows Vulnerabilities
- Linux Vulnerabilities
- mac OS kernels or services Vulnerabilities etc

For example : Privilege escalation bugs, SMB vulnerabilities (EternalBlue), Kernel exploits etc

SOC Detection :

- Sudden privilege changes
- Exploit behavior in EDR
- Kernel driver loading alerts etc...



Network Vulnerabilities

Example of Network Vulnerabilities :

- Open ports
- Weak protocols (Telnet, FTP)
- Unpatched routers/firewalls
- Exposed admin interfaces

SOC Detection :

- IDS/IPS alerts
- Firewall logs
- Excessive authentication failures



Authentication & Authorization Vulnerabilities

Example of Authentication & Authorization Vulnerabilities :

- Weak passwords
- No MFA
- Broken access control
- Privilege escalation paths

SOC Detection :

- IAM alerts
- Access logs
- Role change events



Configuration-Dependent Vulnerabilities

Example of Configuration-Dependent Vulnerabilities :

- Debug mode enabled
- Default credentials
- Excessive permissions

SOC Detection :

- Admin panel exposed
- Default credentials unchanged
- System takeover



Zero-Day Vulnerabilities

A vulnerability which patch does not exist yet as it unknown to the vendor yet and are used by malicious actors like Hackers.

SOC Detection :

- Abnormal processes
- Suspicious network traffic
- Lateral movement

Term

Meaning

Vulnerability

Weakness exists

Exploit

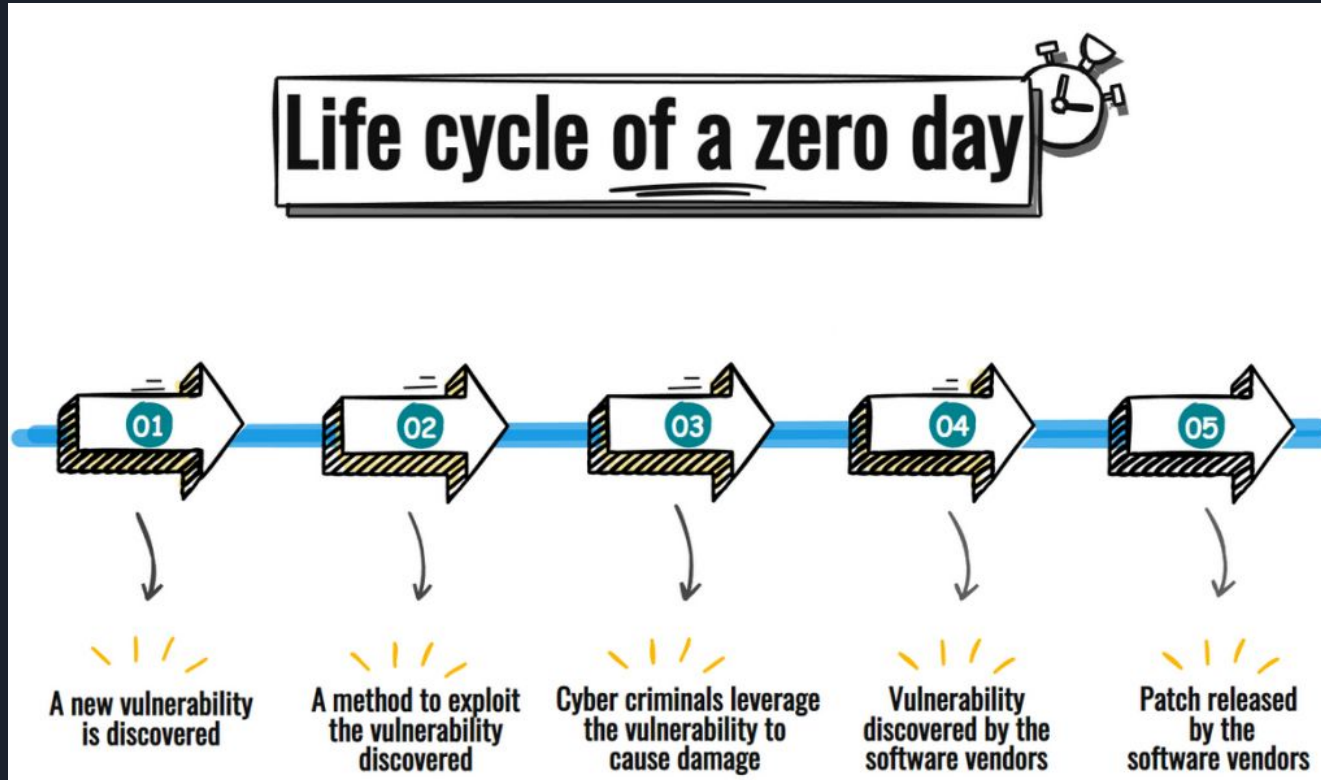
Vulnerability is abused

Incident

Damage or compromise occurs



Zero-Day Vulnerabilities





Zero-Day Vulnerabilities

LIFECYCLE OF A Zero-day attack





Common Misconfigurations For SOC :

Cloud Misconfigurations

- Public S3 buckets
- Open Azure Blob storage
- Over-permissive IAM roles
- Exposed access keys

SOC Example :

S3 bucket public



Sensitive data indexed by search engines



Data breach

Misconfiguration isn't a bug in the software but a mistake in how the system was set up, often by the IT team. These errors happen frequently, usually to make things simpler, like using "1111" instead of typing a long password every time



Network Misconfigurations

- Firewall allows ALL traffic
- Internal services exposed externally
- No network segmentation (All devices on same network)

SOC Example :

Internal DB port exposed



External scan finds it



Database accessed



Identity Misconfigurations

- MFA disabled for admins
- Excessive group memberships
- Shared admin accounts

SOC Example :

Compromised user



User already has admin privileges



No escalation needed



Endpoint Misconfigurations

- Antivirus disabled
- Local admin access
- USB allowed everywhere

SOC Example :

Malware executed



No EDR

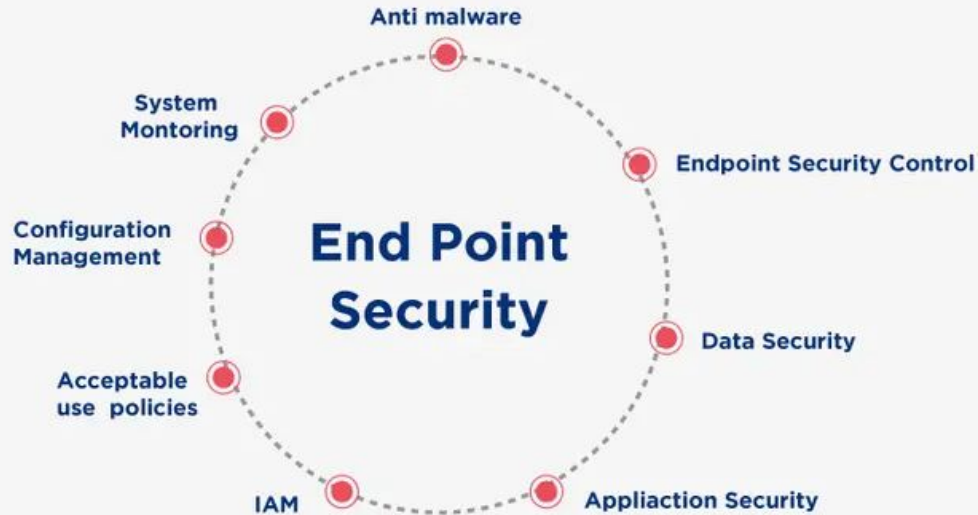


Persistence established

“Most breaches don’t happen because of zero-days, they happen because of misconfigurations and unpatched vulnerabilities.”



Major System Categories Used as Attack Vectors



What is Endpoint Security?

The Policies, processess and technology controls used to protect the confidentiality, intergrity and availability of an endpoint system

Endpoints (User Machines)



Endpoints :

What are endpoints?

- Laptops
- Desktops
- VDI (Virtual Desktop Infrastructure)
- Workstations

How attackers use them :

- Phishing emails → malicious attachments
- Drive-by downloads
- USB-based malware
- Exploiting unpatched software

Why endpoints are dangerous :

- Users have access
- Users click things
- Often weakest security point



Servers (Application / Database / File)

Types :

- Web servers
- App servers
- DB servers
- File servers

How attackers abuse servers :

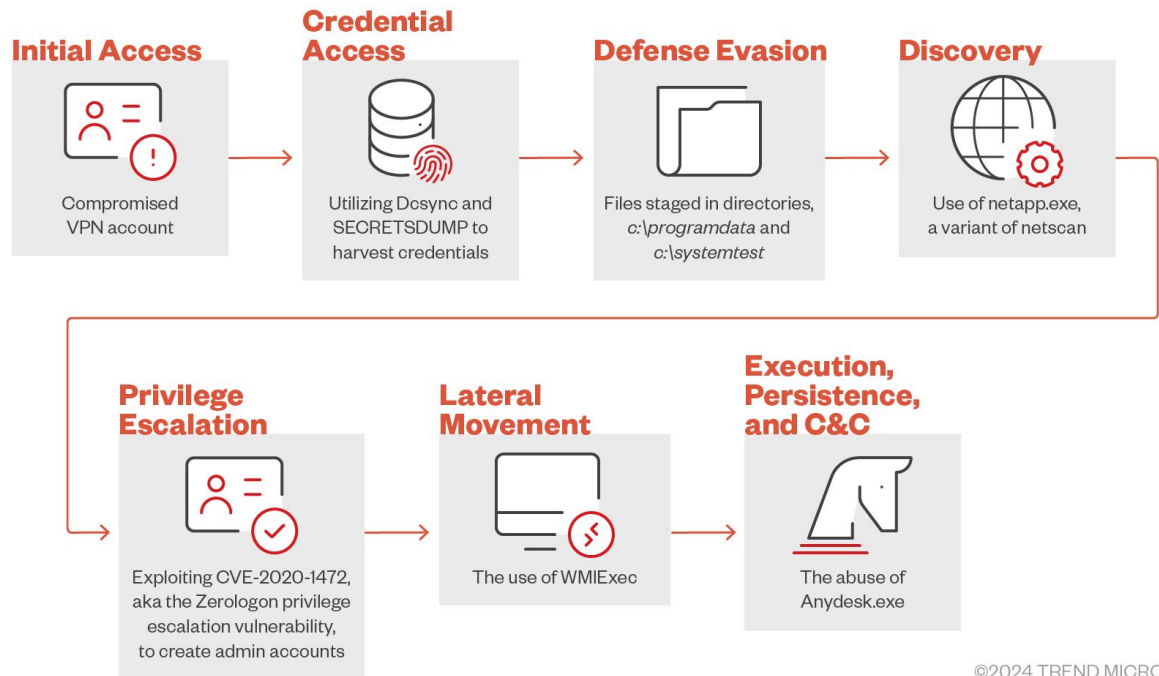
- Exploiting:
- Log4j
- SQL Injection
- RCE vulnerabilities
- Weak admin credentials
- Exposed services

Why servers are high-value :

- Run critical apps
- Store sensitive data
- Often trusted internally



Network Devices (Routers, Firewalls, VPNs)



©2024 TREND MICRO

Devices :

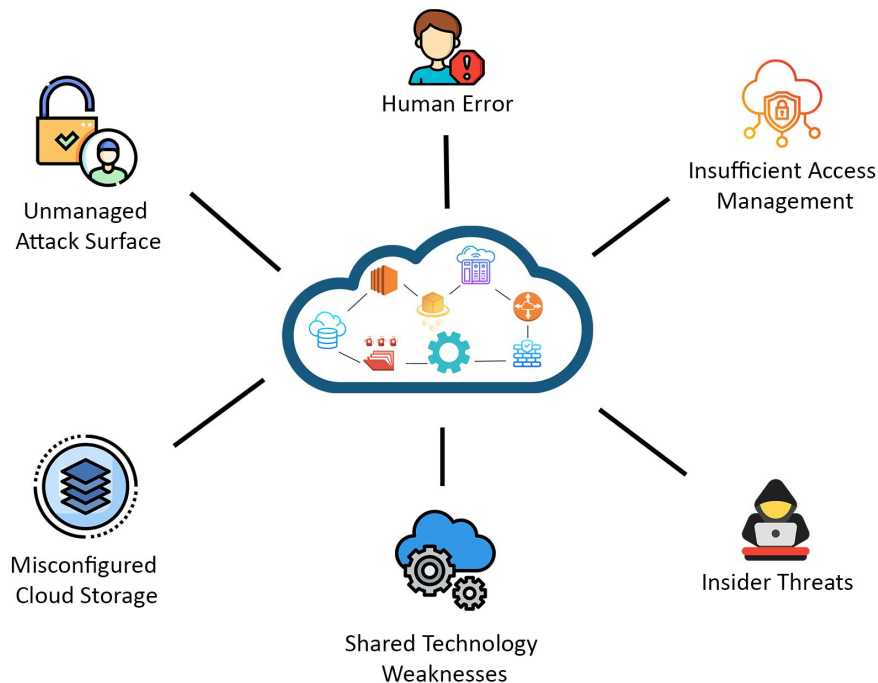
- Routers
- Firewalls
- VPN gateways
- Load balancers

How attackers abuse them :

- Default credentials
- VPN vulnerabilities
- Misconfigured firewall rules
- Firmware exploits



Cloud Systems (AWS / Azure / GCP)



Common cloud attack vectors :

- Public S3 buckets
- Exposed access keys
- Over-permissive IAM roles
- Metadata service abuse